

VULNERABILITY ASSESSMENT REPORT

TARGET:
TESTASP.VULNWEB.COM

Prepared by: Vanga Hasini
Date: April 2026

ABOUT WEBSITE SECURITY ASSESSMENT

A passive, read-only vulnerability assessment was conducted on the publicly accessible website `testasp.vulnweb.com` to identify common security weaknesses visible without intrusive testing. The objective of this review was to evaluate publicly exposed risks, assess the website's overall security posture, and recommend practical remediation steps.

Several Medium and High-risk findings were identified during the assessment, including insecure HTTP usage, missing recommended security headers, vulnerable input functionality, and unnecessary information disclosure. While the target environment is intentionally designed for training purposes, these findings represent real-world risks commonly seen in poorly secured business websites.

KEY OBSERVATIONS

Before reviewing the detailed findings, it is important to understand the broader impact of these risks. Security issues do not only affect systems — they can impact customer trust, business continuity, and regulatory compliance. The most critical issue observed was the lack of encrypted communication over HTTP, which may expose user traffic on insecure networks. Additional missing security headers may increase susceptibility to clickjacking, cross-site scripting impact, and data leakage.

By implementing the recommendations in this report, including HTTPS enforcement, secure headers, and regular vulnerability assessments, an organization can significantly improve its cybersecurity posture and reduce exposure to common web threats.

INCLUDED IN SCOPE

- ♦ **Public-facing web pages**
- ♦ **HTTP response headers**
- ♦ **Browser-visible client-side behavior**
- ♦ **Basic service exposure review**
- ♦ **Publicly observable application functionality**
- ♦ **Metadata and information disclosure checks**

EXCLUDED FROM SCOPE

- ♦ **Exploitation attempts**
- ♦ **Login bypass testing**
- ♦ **Brute-force attacks**
- ♦ **Denial-of-Service testing**
- ♦ **Data modification**
- ♦ **Authentication attacks**
- ♦ **Any harmful activity**

BROWSER DEVTOOLS REVIEW

Used to inspect:

- HTTP/HTTPS behavior
- Response headers
- Cookies
- Client-side scripts
- Network requests

OWASP ZAP PASSIVE SCAN

Used only passive checks to identify:

- Missing headers
- Information leakage
- Cookie weaknesses
- Security misconfigurations

NMAP BASIC RECONNAISSANCE

Used for safe exposure review:

- Open ports
- Web service presence
- Basic banner detection (where visible)

MANUAL REVIEW

Used to inspect:

- Public content disclosures
- Error messages
- Application structure
- Security best-practice gaps

F1 - WEBSITE ACCESSIBLE OVER HTTP

♦ Description

- The target website is accessible over unencrypted HTTP rather than strictly enforcing HTTPS.

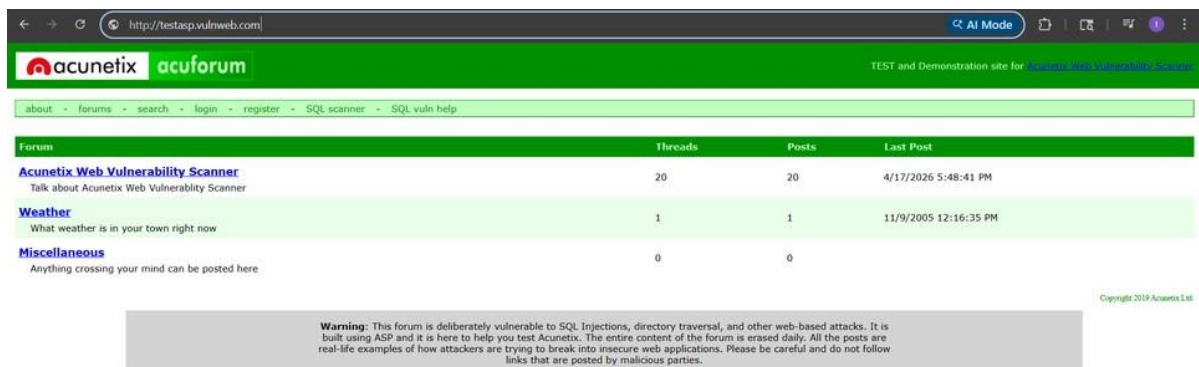
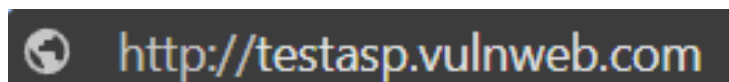
♦ Impact

- Attackers on insecure networks may intercept:
 - Login data
 - Session cookies
 - User traffic
 - Sensitive requests
- This creates risk of man-in-the-middle attacks.

♦ Recommendation

- Force HTTPS on all pages
- Redirect HTTP to HTTPS
- Install valid TLS certificate
- Enable HSTS

♦ Evidence Screenshot



F2 - MISSING SECURITY HEADERS

♦ Description

- Several modern hardening headers are absent or not strongly configured.
- Examples:
 - Content-Security-Policy
 - X-Frame-Options
 - Strict-Transport-Security
 - Referrer-Policy
 - X-Content-Type-Options

♦ Impact

- Missing headers may increase exposure to:
 - Clickjacking
 - Cross-site scripting impact
 - MIME confusion
 - Downgrade attacks
 - Referrer leakage

♦ Recommendation

- Implement recommended headers based on application needs.
- Example:
 - X-Frame-Options: DENY
 - X-Content-Type-Options: nosniff
 - Referrer-Policy: strict-origin-when-cross-origin

♦ Evidence Screenshot

▼ Response headers	☐ Raw
Cache-Control	private
Content-Length	3540
Content-Type	text/html
Date	Fri, 17 Apr 2026 18:03:11 GMT
Server	Microsoft-IIS/8.5
X-Powered-By	ASP.NET

F3 - VULNERABLE APPLICATION INPUTS / KNOWN INSECURE FEATURES

- ♦ **Description**

- **The target environment is intentionally designed as a vulnerable training application and may contain insecure inputs or unsafe request handling patterns.**

- ♦ **Impact**

- **If such flaws existed in production, attackers could exploit:**
 - **SQL Injection**
 - **Input manipulation**
 - **Unauthorized data access**
 - **Database compromise**

- ♦ **Recommendation**

- **Use parameterized queries**
- **Validate user input**
- **Encode output**
- **Apply WAF protections**
- **Conduct secure code reviews**

- ♦ **Evidence Screenshot**

Warning: This forum is deliberately vulnerable to SQL Injections, directory traversal, and other web-based attacks. It is built using ASP and it is here to help you test Acunetix. The entire content of the forum is erased daily. All the posts are real-life examples of how attackers are trying to break into insecure web applications. Please be careful and do not follow links that are posted by malicious parties.

WEBSITE BANNER PUBLICLY STATES THE APPLICATION IS INTENTIONALLY VULNERABLE TO SQL INJECTION AND DIRECTORY TRAVERSAL ATTACKS.

F4 - INFORMATION DISCLOSURE

♦ Description

- Publicly accessible pages and server responses reveal testing purpose, application context, and backend technology details.

♦ Impact

- Attackers may use disclosed information during reconnaissance to identify known vulnerabilities and plan targeted attacks.

♦ Recommendation

- Remove unnecessary banners
- Reduce verbose error messages
- Hide technology identifiers
- Limit public metadata

♦ Evidence Screenshot



About this website

The website was built with the intention to test the Acunetix Web Vulnerability Scanner. For this reason this website have **lot of bugs** to demonstrate the forementioned software's capabilities to find those bugs.

Please DO NOT use this website as a forum site. DO NOT post any sensitive information on this site. This includes e-mail addresses or real names.

About Acunetix

Combating the web vulnerability threat

Securing a company's web applications is today's most overlooked aspect of securing the enterprise. Web application hacking is on the rise with as many as 75% of cyber attacks done at web application level or via the web. Most corporations have secured their data at the network level, but have overlooked the crucial step of checking whether their web applications are vulnerable to attack. Web applications, which often have a direct line into the company's most valuable data assets, are online 24/7, completely unprotected by a firewall and therefore easy prey for attackers.

Acunetix was founded with this threat in mind. We realised the only way to combat web site hacking was to develop an automated tool that could help companies scan their web applications for vulnerabilities. In July 2005, Acunetix Web Vulnerability Scanner was released - a tool that crawls the website for vulnerabilities to SQL injection, cross site scripting and other web attacks before hackers do.

The Acunetix development team consists of highly experienced security developers who have each spent years developing network security scanning software prior to starting development on Acunetix WVS. The management team is backed by years of experience marketing and selling security software.

Acunetix is a privately held company with its [offices](#) in Malta, US and the UK.

PUBLIC ABOUT PAGE REVEALS APPLICATION PURPOSE AND ENVIRONMENTAL DETAILS THAT MAY ASSIST RECONNAISSANCE EFFORTS.

PRIORITY 1 - IMMEDIATE ACTIONS

1. *Enforce HTTPS*
 - *Redirect all HTTP traffic to HTTPS.*
2. *Add Security Headers*
 - *Implement CSP, HSTS, and X-Frame-Options.*
3. *Secure Inputs*
 - *Validate forms, search fields, and parameters.*
4. *Hide Technical Details*
 - *Remove unnecessary banners and version disclosures.*

PRIORITY 2 - ONGOING ACTIONS

5. *Update Systems*
 - *Keep servers and frameworks patched.*
6. *Regular Security Reviews*
 - *Perform monthly vulnerability scans.*
7. *Secure Development*
 - *Apply security in the SDLC process.*
8. *Staff Awareness*
 - *Provide cybersecurity training regularly.*

CONCLUSION

A passive security assessment of testasp.vulnweb.com identified several weaknesses commonly found in poorly secured web environments. The findings highlight the importance of implementing HTTPS, security headers, hardened server configurations, and secure coding practices.

Although this target is intentionally vulnerable for training purposes, the same issues on a real business website could expose sensitive user data, damage brand reputation, and create legal or operational risks.

This assessment demonstrates how even basic security misconfigurations can significantly weaken an organization's overall security posture. Regular reviews, timely updates, and proactive remediation are essential to maintaining a secure web presence.

By implementing the recommendations outlined in this report, an organization can significantly improve its cybersecurity posture and reduce exposure to common web-based threats.